LAPORAN AUDIT KEAMANAN WEBSITE

Spencer Web Security Audit Tool

Target Website	bgn.go.id
URL Lengkap	https://bgn.go.id/
Tanggal Audit	21 May 2026, 11:35:37 WIB
Metode	OWASP Top 10 + CVSS Scoring
Tool	SpencerWeb v2.0
Durasi Scan	70.32 detik

SECURITY GRADE: D **SKOR: 52/100**

1. RINGKASAN EKSEKUTIF

Audit keamanan website **bgn.go.id** telah dilakukan pada tanggal **21 May 2026, 11:35:37 WIB** menggunakan Spencer Web Security Audit Tool. Audit ini menggunakan metodologi OWASP Top 10 dengan sistem penilaian risiko CVSS yang disederhanakan menjadi grade A-F.

Berdasarkan 124 pengecekan keamanan yang dilakukan, sistem mendapat grade **D** dengan skor **52/100**. Ditemukan total **15 kerentanan** yang terdiri dari:

Severity	Jumlah	Dampak
CRITICAL	0	Risiko tertinggi, harus segera diperbaiki
HIGH	4	Risiko tinggi, perbaiki dalam waktu dekat
MEDIUM	3	Risiko sedang, jadwalkan perbaikan
LOW	8	Risiko rendah, perbaikan opsional

2. METODOLOGI AUDIT

Audit ini dilakukan menggunakan pendekatan **Black-box Testing** — auditor tidak memiliki akses ke source code maupun infrastruktur internal, dan hanya berinteraksi dengan target sebagaimana attacker dari luar.

Framework yang digunakan:
• **OWASP Top 10** — standar industri untuk web application security testing
• **OWASP Testing Guide v4** — panduan teknis pengujian per kategori
• **CVSS v3.1** — Common Vulnerability Scoring System untuk penilaian risiko

Module yang dijalankan:
1. HTTP Security Headers Audit (Passive)
2. SSL/TLS Certificate Audit (Passive)
3. Sensitive File Exposure Scan (Passive)
4. CMS Detection & Version Check (Passive)
5. WordPress Plugin & Theme Scanner (Passive)
6. SQL Injection Scanner — Error, Boolean, Time-based (Active)
7. Reflected XSS Scanner (Active)
8. Stored XSS Scanner (Active)
9. CSRF Protection Checker (Active)
10. Open Port Reconnaissance (Active)

3. TEMUAN KERENTANAN

Temuan #1: Strict-Transport-Security	HIGH
Deskripsi:	Memaksa browser selalu menggunakan HTTPS
Rekomendasi:	Tambahkan header: Strict-Transport-Security: max-age=31536000; includeSubDomains

Temuan #2: Content-Security-Policy	HIGH
Deskripsi:	Mencegah XSS dan injeksi konten berbahaya
Rekomendasi:	Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

Temuan #3: Cookie: HWWAFSESID (session)	HIGH
Deskripsi:	Cookie 'HWWAFSESID' memiliki 3 masalah: Missing Secure flag; Missing HttpOnly flag; SameSite=Missing
Rekomendasi:	Set flag: Secure, HttpOnly, SameSite=Lax pada cookie 'HWWAFSESID'

Temuan #4: Port 9200/Elasticsearch	HIGH
Deskripsi:	Port 9200 (Elasticsearch) TERBUKA — Elasticsearch exposed — data leak
Rekomendasi:	Tutup port 9200 via firewall jika tidak diperlukan. Jika diperlukan, batasi akses via IP allowlist.

Temuan #5: X-Content-Type-Options	MEDIUM
Deskripsi:	Mencegah MIME-type sniffing
Rekomendasi:	Tambahkan header: X-Content-Type-Options: nosniff

Temuan #6: Cookie: HWWAFSESID	MEDIUM
Deskripsi:	Cookie tidak aman: Missing 'Secure' flag, Missing 'HttpOnly' flag
Rekomendasi:	Set flag Secure dan HttpOnly pada semua cookie sensitif

Temuan #7: Cookie: HWWAFSESTIME	MEDIUM
Deskripsi:	Cookie tidak aman: Missing 'Secure' flag, Missing 'HttpOnly' flag
Rekomendasi:	Set flag Secure dan HttpOnly pada semua cookie sensitif

Temuan #8: X-XSS-Protection	LOW
Deskripsi:	Mengaktifkan filter XSS bawaan browser (legacy)
Rekomendasi:	Tambahkan header: X-XSS-Protection: 1; mode=block (atau gunakan CSP sebagai pengganti)

Temuan #9: Referrer-Policy	LOW
Deskripsi:	Mengontrol informasi referrer yang dikirim browser
Rekomendasi:	Tambahkan header: Referrer-Policy: strict-origin-when-cross-origin

Temuan #10: Permissions-Policy	LOW
Deskripsi:	Mengontrol akses fitur browser (kamera, mikrofon, geolokasi)
Rekomendasi:	Tambahkan header: Permissions-Policy: geolocation=(), camera=(), microphone=()

Temuan #11: Server (Info Leak)	LOW
Deskripsi:	Terdeteksi: CW — Membocorkan versi web server (misal: Apache/2.4.41)
Rekomendasi:	Sembunyikan atau hapus header Server dari response

Temuan #12: Info Leak: Email Address [/]	LOW
Deskripsi:	Email address ditemukan di source code — bisa digunakan untuk phishing/spam. Value (masked): halo****o.id
Rekomendasi:	Jangan hardcode email di HTML. Gunakan form kontak atau obfuscation.

Temuan #13: Directory: /robots.txt	LOW
Deskripsi:	Path /robots.txt accessible (HTTP 200, 68 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #14: security.txt (missing)	LOW
Deskripsi:	security.txt tidak ditemukan — best practice adalah menyediakan file ini agar security researcher tahu cara melaporkan kerentanan
Rekomendasi:	Buat file /.well-known/security.txt sesuai RFC 9116. Minimal berisi Contact: dan Expires: fields.

Temuan #15: WAF Detection	LOW
Deskripsi:	Tidak terdeteksi WAF (Web Application Firewall) — website mungkin tidak menggunakan layer proteksi tambahan
Rekomendasi:	Pertimbangkan menggunakan WAF seperti Cloudflare, AWS WAF, atau ModSecurity untuk proteksi tambahan terhadap serangan web

4. DETAIL HASIL PER MODULE

Module 1 — HTTP Security Headers

Passed: **3** | Failed: **9** | Total: **12**

Check	Severity
Strict-Transport-Security	HIGH
Content-Security-Policy	HIGH
X-Content-Type-Options	MEDIUM
X-XSS-Protection	LOW
Referrer-Policy	LOW
Permissions-Policy	LOW
Server (Info Leak)	LOW
Cookie: HWWAFSESID	MEDIUM
Cookie: HWWAFSESTIME	MEDIUM

Module 2 — SSL/TLS Certificate

Passed: **6** | Failed: **0** | Total: **6**

Module 3 — Sensitive File Exposure

Passed: **35** | Failed: **0** | Total: **35**

Module 4 — CMS Detection

Passed: **1** | Failed: **0** | Total: **1**

Module 6 — Advanced SQL Injection

Passed: **1** | Failed: **0** | Total: **1**

Module 7 — Reflected XSS

Passed: **1** | Failed: **0** | Total: **1**

Module 9 — CSRF Protection

Passed: **1** | Failed: **0** | Total: **1**

Module 10 — Port Reconnaissance

Passed: **86** | Failed: **1** | Total: **87**

Check	Severity
Port 9200/Elasticsearch	HIGH

5. KESIMPULAN DAN SARAN PRIORITAS

Berdasarkan hasil audit, website **bgn.go.id** memiliki **0 kerentanan CRITICAL** dan **4 kerentanan HIGH** yang memerlukan perhatian segera.

Saran prioritas perbaikan:

1. [HIGH] Strict-Transport-Security
Tambahkan header: Strict-Transport-Security: max-age=31536000; includeSubDomains

2. [HIGH] Content-Security-Policy
Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

3. [HIGH] Cookie: HWWAFSESID (session)
Set flag: Secure, HttpOnly, SameSite=Lax pada cookie 'HWWAFSESID'

4. [HIGH] Port 9200/Elasticsearch
Tutup port 9200 via firewall jika tidak diperlukan. Jika diperlukan, batasi akses via IP allowlist.

5. [MEDIUM] X-Content-Type-Options
Tambahkan header: X-Content-Type-Options: nosniff

DISCLAIMER

Laporan ini dihasilkan secara otomatis oleh Spencer Web Security Audit Tool. Audit dilakukan pada waktu dan kondisi tertentu; kondisi keamanan website dapat berubah seiring waktu. Hasil audit ini hanya mencakup parameter yang diuji oleh tool dan tidak menggantikan audit keamanan manual oleh professional security expert. Beberapa temuan automated scanner dapat berupa false positive dan harus diverifikasi secara manual sebelum tindakan perbaikan diambil.

Generated by Spencer v2.0 — 21 May 2026